

Manual 09 - Implementação Controlada do NIST Cybersecurity Framework 2.0

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: 321d4fd0e034995ef589a3308af53cab361a9859 | Idioma: pt-BR | limites de resultados do CSF e de decisão humana mantidos.

Limite de asseguuração: Este manual operacionaliza resultados do NIST CSF 2.0, mas não cria certificação NIST, não garante efetividade de cibersegurança, não estabelece conformidade legal nem prova que um conjunto de controles seja universalmente suficiente. Perfis, Tiers, exceções, risco residual e decisões materiais exigem julgamento humano responsável.

Caminhos de implementação

Manual 09 — Caminhos de implementação do NIST CSF 2.0

Rascunho controlado assistido por máquina (pt-BR). A edição em inglês continua sendo a fonte controlada. Esta localização não constitui aprovação semântica ou terminológica humana e permanece sujeita à etapa de revisão humana antes da publicação.

Objetivo

Estes caminhos traduzem os resultados do NIST CSF 2.0 em padrões operacionais proporcionais sem tratar o Framework como um catálogo prescritivo de controles ou como um esquema de certificação. Cada caminho exige contexto organizacional explícito, estratégia de risco, Perfil Alvo, responsáveis, evidências, tratamento de exceções e decisões humanas.

Caminho Essencial

Use quando a complexidade organizacional e a exposição de cibersegurança permitirem uma implementação focada.

Padrão operacional mínimo:

- estabelecer governança de cibersegurança e responsabilidade pelo risco;
- definir serviços críticos de missão/negócio e suas dependências;
- manter um Perfil Atual básico e um Perfil Alvo orientado por risco;
- identificar ativos, dados, serviços, fornecedores e dependências tecnológicas importantes;
- manter um registro priorizado de riscos de cibersegurança;
- implementar identidade/aceso, proteção de dados, proteção de plataformas, monitoramento, resposta a incidentes e recuperação de forma proporcional ao risco;
- definir rotas de escalonamento para incidentes e riscos materiais;
- manter evidências de decisões, testes, incidentes, exceções e remediações significativas;
- revisar o progresso e mudanças materiais em uma cadência definida.

A conclusão exige evidências de que a organização consegue explicar seus resultados CSF prioritários, lacunas atuais, ações responsáveis, risco residual aceito e próximo ponto de revisão.

Caminho Estruturado

Use quando múltiplas unidades de negócio, obrigações reguladas, fornecedores materiais ou ambientes tecnológicos mais complexos exigirem governança repetível.

Adiciona ao Essencial:

- Perfis Atual e Alvo empresariais formais;
- uso definido dos Implementation Tiers do CSF como contexto para características de governança de risco de cibersegurança, e não como certificados de maturidade;
- integração com gestão de riscos corporativos e relatórios executivos;
- funções, competências, demanda de força de trabalho e planos de treinamento documentados;

- governança sistemática de fornecedores e risco da cadeia de suprimentos cibernética;
- métricas vinculadas a resultados e decisões, e não apenas a contagens de atividade;
- mapeamentos formais de controles/evidências usando referências informativas autorizadas quando úteis;
- desafio independente ou de segunda linha para decisões de risco material;
- playbooks testados de resposta e recuperação vinculados às prioridades de negócio;
- reavaliação periódica de Perfis e planejamento de melhorias.

A conclusão exige evidências rastreáveis nas seis Funções e um plano de melhoria aprovado para lacunas materiais.

Caminho Aprimorado

Use quando importância sistêmica, exposição a ameaças, complexidade regulatória, serviços críticos ou apetite de risco da organização justificarem integração e assecuração mais profundas.

Adiciona ao Estruturado:

- análise quantitativa ou baseada em cenários quando útil para decisões;
- monitoramento contínuo ou de alta frequência de resultados materiais e sinais de controle;
- cruzamentos e fluxos de referências informativas consumíveis por máquina com proveniência e validação;
- análise avançada de concentração de fornecedores, quartas partes, resiliência e risco de saída;
- testes orientados por ameaças e exercícios adversariais;
- coleta automatizada de evidências com controles de integridade, linhagem, acesso e exceções;
- relatórios de risco para executivos e conselho vinculados a objetivos corporativos e apetite de risco;
- mapeamento entre frameworks que preserve a semântica da fonte e não implique equivalência quando ela não existir;
- assecuração formal sobre resultados selecionados de alto risco;
- melhoria contínua baseada em incidentes, quase incidentes, testes, achados de auditoria, mudanças de negócio e inteligência de ameaças.

A conclusão exige evidências de que práticas automatizadas ou avançadas permanecem governadas por decisões humanas responsáveis e de que exceções ou limitações de ferramentas/modelos estão visíveis.

Ciclo operacional das seis Funções

1. GOVERN estabelece contexto, objetivos, estratégia de risco, políticas, funções, supervisão e expectativas da cadeia de suprimentos.
2. IDENTIFY determina o que importa, o que pode dar errado e onde é necessário melhorar.
3. PROTECT implementa salvaguardas proporcionais ao risco priorizado.
4. DETECT fornece percepção oportuna de eventos e condições adversas relevantes.
5. RESPOND contém, analisa, comunica e mitiga incidentes de cibersegurança.
6. RECOVER restaura capacidades e incorpora lições à governança e melhoria futuras.

O ciclo é iterativo. Mudanças materiais, incidentes, testes com falha, mudanças de fornecedores ou pressupostos de risco alterados devolvem as decisões afetadas a GOVERN e IDENTIFY.

Gráfico de memória do Manual 09 1

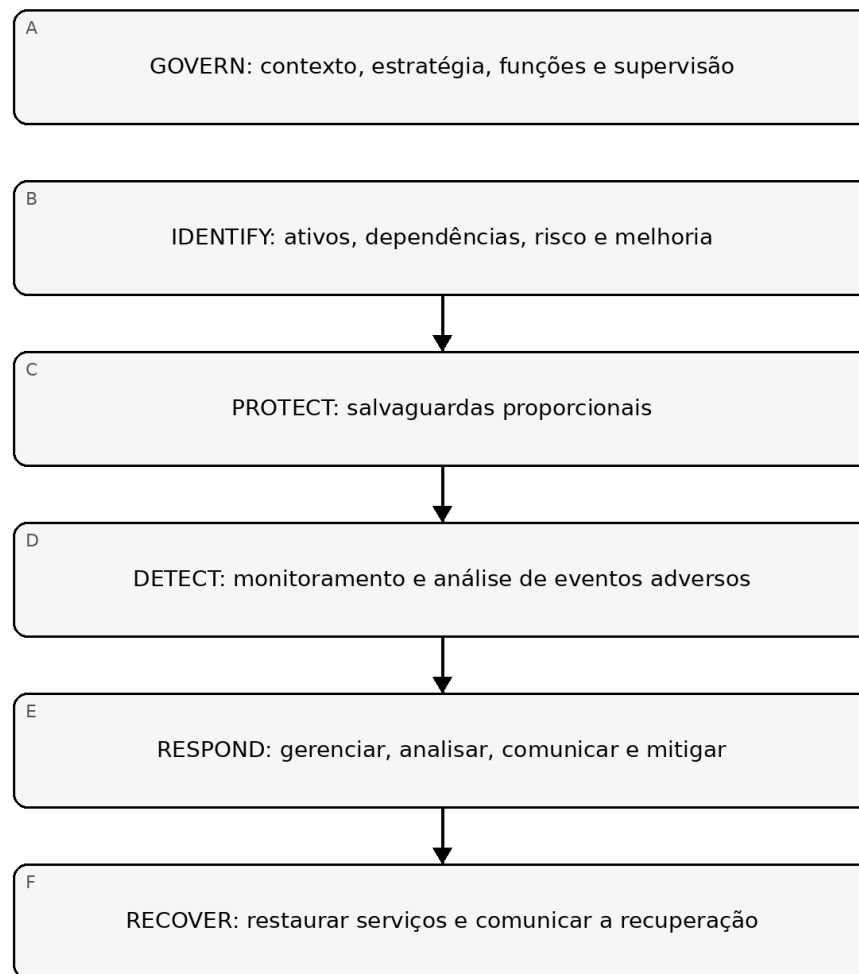


Figura 1. Gráfico de memória de implementação

Explicação acessível: As seis Funções do NIST CSF 2.0 operam como um ciclo conectado, e não como listas de verificação isoladas. A governança estabelece o contexto para identificar e proteger; a detecção informa a resposta; e a recuperação devolve lições, pressupostos alterados e prioridades de melhoria à governança.

Caminho de Perfis e melhoria

Gráfico de memória do Manual 09 2

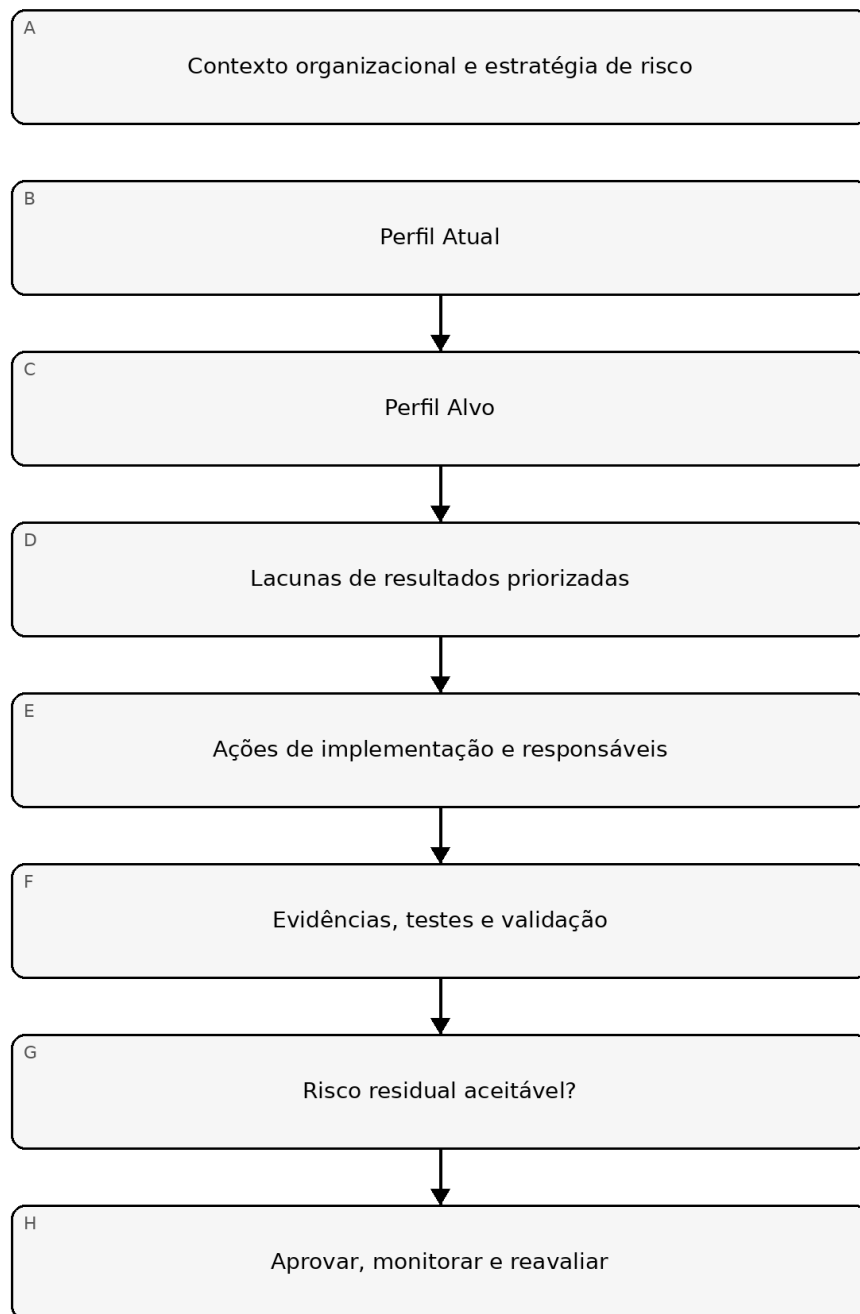


Figura 2. Gráfico de memória de implementação

Explicação acessível: A implementação do CSF começa pelo contexto organizacional, compara os Perfis Atual e Alvo, prioriza lacunas de resultados, implementa ações com responsáveis e valida evidências. Risco residual inaceitável retorna ao tratamento; risco aceito permanece monitorado e é reavaliado quando as condições mudam.

Roteamento de implementação proporcional

Gráfico de memória do Manual 09 3

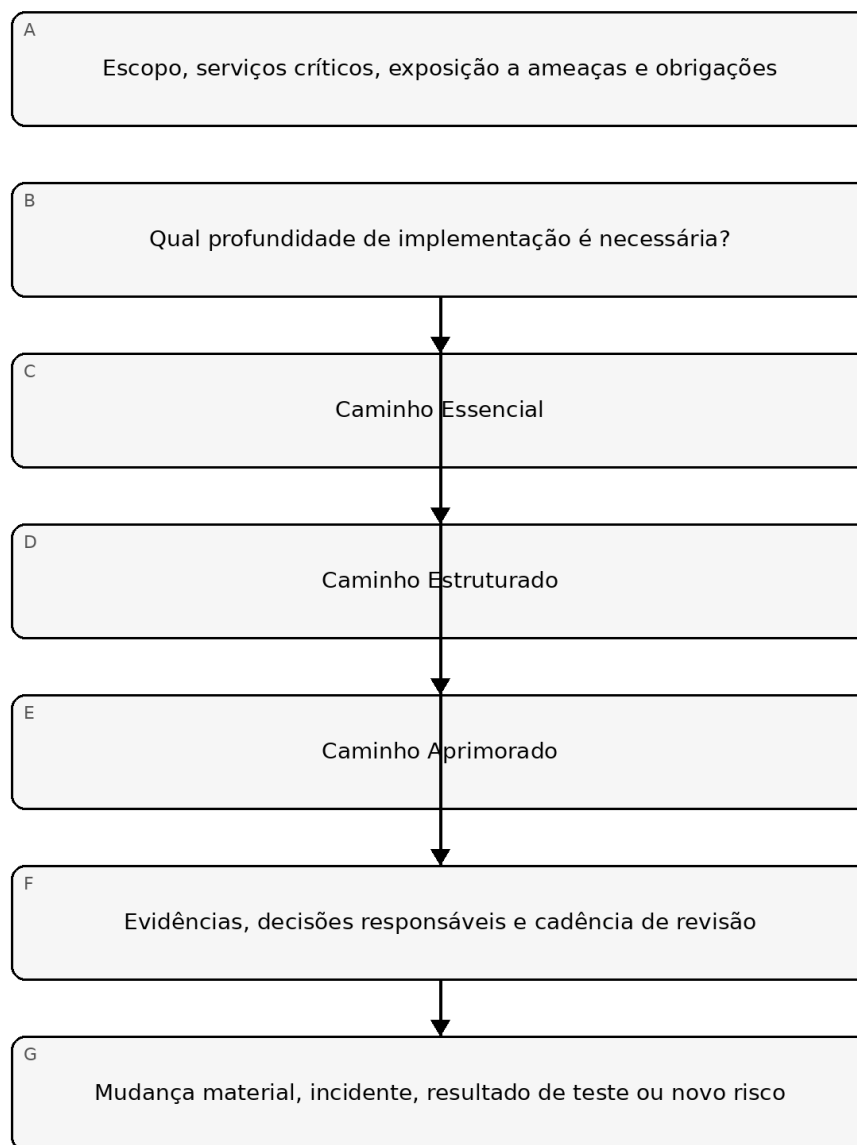


Figura 3. Gráfico de memória de implementação

Explicação acessível: Os caminhos Essencial, Estruturado e Aprimorado dimensionam a profundidade da implementação ao contexto e à exposição da organização. Todos preservam evidências, decisões responsáveis e reavaliação; mudanças materiais ou novos riscos podem exigir profundidade diferente em vez de fixar permanentemente a organização em um nível.

Ciclo de evidência e decisão

Para cada resultado CSF material, registre:

- referência de resultado/subcategoria;
- aplicabilidade organizacional e justificativa;
- método de implementação;

- responsável;
- evidência esperada e observada;
- método de teste ou validação quando aplicável;
- lacuna/achado;
- consequência de risco;
- tratamento ou exceção;
- data-alvo;
- risco residual;
- aprovador;
- próxima data de revisão.

Uma declaração de política, compra de ferramenta, resposta de questionário ou controle mapeado não é suficiente, isoladamente, para demonstrar um resultado.

Condições de parada e reversão

A implementação ou publicação para quando o escopo material é desconhecido, lacunas de alto risco não têm tratamento responsável, evidências contradizem resultados declarados, fontes autorizadas estão desatualizadas ou não resolvidas, mapeamentos automatizados não têm proveniência/validação, a revisão humana exigida está incompleta ou uma mudança material invalida uma aprovação anterior.

Declaração de asseguração

O Manual 09 é orientação de implementação. O uso do manual não cria certificação NIST, não garante efetividade de cibersegurança, não estabelece conformidade legal ou regulatória e não prova que um conjunto específico de controles seja suficiente para toda organização. As organizações continuam responsáveis por decisões de risco específicas ao seu contexto e por revisão humana competente.

Manual controlado de 32 capítulos

Capítulo 01 — Contexto organizacional e dependência da missão

Defina missão, objetivos de negócio, serviços críticos, partes interessadas, contexto legal e contratual, ambiente tecnológico e dependências externas que moldam o risco cibernético. O registro deve deixar claro quais resultados importam mais e por quê.

A evidência de implementação deve incluir escopo, serviços críticos, mapas de dependência, responsáveis, premissas e questões de escopo não resolvidas. Mudanças materiais no negócio ou na tecnologia devem provocar reavaliação.

Capítulo 02 — Governança do risco cibernético

Estabeleça direitos de decisão sobre risco cibernético, incluindo responsabilidade executiva, caminhos de escalonamento, autoridade delegada, fóruns de supervisão e relação com a gestão de riscos corporativos.

A evidência deve demonstrar quem pode aceitar risco, quem desafia decisões, como assuntos materiais chegam à liderança e como a segurança cibernética entra em decisões de estratégia, investimento, aquisições, terceirização e mudanças.

Capítulo 03 — Estratégia e apetite de risco

Traduza objetivos corporativos em premissas, prioridades, tolerâncias, expectativas de resposta e limites de escalonamento para risco cibernético. A estratégia deve ser utilizável em decisões reais e não ficar restrita a linguagem de política.

Documento apetite de risco ou critérios equivalentes, opções de tratamento, regras de exceção, cadência de revisão e tratamento da incerteza.

Capítulo 04 — Papéis, responsabilidades e autoridades

Defina responsabilidades de segurança cibernética entre liderança, tecnologia, segurança, jurídico, privacidade, compras, RH, operações, gestão de incidentes, resiliência e fornecedores quando aplicável.

A evidência deve identificar responsáveis, operadores, especialistas consultados, autoridade de aprovação, segregação de funções, substitutos e lacunas de capacidade.

Capítulo 05 — Políticas e expectativas de controle

Políticas e padrões devem traduzir a estratégia de risco em expectativas acionáveis, permitindo implementação específica ao contexto. Mantenha propriedade, aprovação, versionamento, exceções, datas de revisão e registros de comunicação.

Uma política não prova que um resultado foi alcançado. São necessárias evidências operacionais, técnicas, de testes e de comportamento quando relevantes.

Capítulo 06 — Supervisão e revisão de desempenho

A liderança deve revisar risco cibernético, achados materiais, incidentes, exceções, problemas com fornecedores, prontidão de recuperação e progresso de melhoria por meio de informações úteis para decisão.

Métricas devem se conectar a resultados e risco. Contagens de atividades não devem ser tratadas como prova de redução efetiva de risco.

Capítulo 07 — Governança da cadeia de suprimentos cibernética

Defina como fornecedores, prestadores de serviço, software, nuvem, dados, IA e outras dependências externas entram na governança cibernética. Aplique diligência proporcional, contratação, monitoramento, coordenação de incidentes, análise de concentração e planejamento de saída.

A evidência de fornecedores deve permanecer rastreável a serviços críticos e decisões de risco, evitando uma abordagem apenas de questionário.

Capítulo 08 — Gate fail-closed de GOVERNAR

GOVERNAR está incompleto quando o escopo material não está resolvido, a autoridade de risco é incerta, a liderança não tem visibilidade sobre risco significativo, exceções de alto risco não têm aceitação autorizada ou dependências de fornecedores não são governadas proporcionalmente.

A QA automatizada pode validar estrutura e campos esperados de evidência, mas a suficiência da governança exige julgamento humano competente.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.

Capítulo 09 — Inventário de ativos e serviços

Mantenha visibilidade suficiente de sistemas, aplicações, dados, identidades, instalações, serviços em nuvem, tecnologia operacional, fornecedores e serviços de negócio para apoiar decisões de risco. Inventários devem identificar responsáveis, criticidade, dependências, estado do ciclo de vida e elementos desconhecidos.

Ativos não gerenciados ou não identificados devem ser tratados como risco que exige investigação.

Capítulo 10 — Avaliação de risco cibernético

Identifique ameaças, vulnerabilidades, exposição, probabilidade ou plausibilidade, consequências, salvaguardas existentes, incerteza e objetivos afetados usando método repetível e apropriado ao contexto.

A evidência deve distinguir fatos, premissas, estimativas e limitações. Pontuações sem raciocínio rastreável não constituem evidência suficiente.

Capítulo 11 — Priorização de risco e melhoria

Converta resultados de avaliações, incidentes, testes, auditorias, mudanças de negócio e inteligência de ameaças em ações priorizadas. Registre responsáveis, prazos, dependências, medidas provisórias, risco residual e escalonamento.

A melhoria deve ser contínua e orientada por risco, não limitada a ciclos periódicos de conformidade.

Capítulo 12 — Gestão de identidade e acesso

Gerencie identidades, credenciais, autenticação, autorização, acesso privilegiado, contas de serviço e ciclo de vida de acesso de acordo com risco e necessidade de negócio.

A evidência deve suportar controles de admissão/mudança/desligamento, governança de privilégios, revisão periódica, tratamento de exceções e remoção tempestiva de acessos desnecessários.

Capítulo 13 — Conscientização e resiliência da força de trabalho

Defina expectativas de conhecimento e comportamento em segurança cibernética para colaboradores e terceiros relevantes. O treinamento deve refletir função, acesso, exposição a ameaças e responsabilidades.

Registre atribuição, conclusão, atrasos, requisitos por função, lições de incidentes e resultados mensuráveis quando possível.

Capítulo 14 — Segurança de dados

Proteja dados conforme sensibilidade, valor, requisitos legais ou contratuais, estágio do ciclo de vida e exposição a ameaças. Considere acesso, criptografia ou proteção equivalente quando apropriado, integridade, backup, retenção, transferência, descarte e risco de vazamento.

Afirmações de proteção devem ser sustentadas por inventários, configurações, monitoramento, testes ou outra evidência relevante.

Capítulo 15 — Segurança de plataformas e configuração

Estabeleça configuração segura baseada em risco, gestão de vulnerabilidades e correções, defesa contra malware, controles de endpoints/servidores/nuvem, integridade de software e gestão do ciclo de vida.

Exceções, tecnologia sem suporte, controles compensatórios e responsáveis por remediação devem permanecer visíveis.

Capítulo 16 — Resiliência de infraestrutura e gate de PROTEGER

Projete redes, serviços, instalações, dependências de nuvem, backups, capacidade, segmentação, redundância e salvaguardas de recuperação conforme criticidade e risco.

PROTEGER está incompleto quando salvaguardas críticas são desconhecidas, vulnerabilidades materiais não têm tratamento responsável, acesso privilegiado não está controlado, proteções de dados não podem ser evidenciadas ou premissas de resiliência não foram testadas.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.

Capítulo 17 — Estratégia de monitoramento contínuo

Defina quais condições, eventos, ativos, identidades, serviços, fornecedores e sinais de controle exigem monitoramento. Estabeleça fontes de telemetria, responsáveis, cobertura, retenção, proteção, cadência de revisão e pontos cegos conhecidos.

A evidência deve identificar fontes ausentes ou pouco confiáveis; a simples implantação de uma ferramenta não demonstra visibilidade efetiva.

Capítulo 18 — Detecção de eventos adversos

Use sinais técnicos e operacionais para identificar possíveis eventos de segurança cibernética. A lógica de detecção deve ser orientada por risco, testada, ajustada, versionada quando apropriado e conectada a processos responsáveis de triagem.

Registre cobertura, preocupações com falsos positivos e falsos negativos, limiares de escalonamento e lacunas materiais.

Capítulo 19 — Análise e correlação de eventos

Analise eventos usando contexto relevante, como criticidade do ativo, identidade, comportamento, inteligência de ameaças, vulnerabilidades, impacto de negócio e atividades relacionadas. Preserve evidência suficiente para decisões e revisão posterior.

Correlação automatizada ou análise apoiada por IA não deve ocultar incerteza, inferência sem suporte, lacunas de procedência ou a necessidade de escalonamento humano.

Capítulo 20 — Declaração e coordenação de incidentes

Defina critérios e autoridade para declarar incidentes, atribuir severidade, ativar estruturas de resposta e coordenar segurança, tecnologia, negócio, jurídico, privacidade, comunicações, resiliência e fornecedores.

O registro deve capturar quem tomou decisões materiais, quando, com base em quais evidências e com quais premissas não resolvidas.

Capítulo 21 — Contenção e mitigação

Contenha e mitigue incidentes usando ações predefinidas e específicas da situação que considerem consequências operacionais, de segurança, legais, probatórias e de recuperação.

Registre responsável, horário, justificativa, sistemas afetados, validação, necessidades de rollback e risco residual.

Capítulo 22 — Comunicações de incidentes

Planeje comunicações internas e externas, escalonamento, coordenação com partes interessadas, análise de notificações regulatórias ou contratuais e interação com fornecedores/clientes conforme aplicável.

Automação pode apoiar roteamento e redação, mas não deve tomar decisões legais de notificação sem revisão humana.

Capítulo 23 — Evidência de resposta e lições aprendidas

Preserve cronologias, alertas, logs, evidência forense, decisões, comunicações, ações de contenção, achados, perguntas em aberto e ações de acompanhamento. Realize revisão de lições proporcional à importância do incidente.

As lições devem alimentar governança, avaliação de risco, arquitetura, detecção, treinamento, supervisão de fornecedores e recuperação.

Capítulo 24 — Gate fail-closed de DETECTAR e RESPONDER

DETECTAR e RESPONDER estão incompletos quando pontos cegos materiais não são reconhecidos, a autoridade de incidente é incerta, alertas críticos não são triados, a preservação de evidência é inadequada ou ações significativas não podem ser reconstruídas.

A QA do repositório pode validar registros esperados e controles estruturais; efetividade de incidentes e obrigações legais exigem avaliação humana competente.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.

Capítulo 25 — Planejamento e priorização da recuperação

Defina prioridades de recuperação a partir de impacto de missão e negócio, dependências de serviços críticos, risco, segurança, integridade de dados, necessidades contratuais e expectativas das partes interessadas. Estabeleça papéis, rotas de comunicação, dependências, critérios de restauração e opções de contingência.

Os planos devem identificar premissas e dependências que podem falhar em um incidente real.

Capítulo 26 — Execução e validação da recuperação

Restaurar capacidades afetadas usando prioridades controladas e decisões baseadas em evidência. Valide funcionalidade, segurança, integridade de dados, acesso, monitoramento e risco não resolvido antes de declarar a recuperação concluída.

Os registros devem distinguir restauração temporária, remediação permanente, risco residual aceito e trabalho de acompanhamento.

Capítulo 27 — Comunicação e melhoria da recuperação

Coordene status e expectativas de recuperação com liderança, responsáveis de negócio, equipes técnicas, fornecedores, clientes e outras partes relevantes. Capture lições e alimente governança, avaliação de risco, arquitetura, resposta e planejamento de resiliência.

Fraquezas recorrentes de recuperação devem se tornar itens visíveis de melhoria.

Capítulo 28 — Perfis Organizacionais

Use Perfis Atuais e Alvo para descrever resultados selecionados do CSF no contexto organizacional, identificar lacunas, priorizar melhorias e comunicar decisões de risco. Controle escopo, justificativa, premissas, responsáveis, evidência e datas de revisão.

Perfis são ferramentas de decisão, não certificados nem pontuações universais de maturidade.

Capítulo 29 — Perfis de Comunidade e requisitos compartilhados

Quando forem usados Perfis setoriais, comunitários, de ecossistema ou missão, mapeie-os de forma transparente ao contexto organizacional. Registre onde expectativas compartilhadas se aplicam, onde é necessária adaptação local e como conflitos ou lacunas são resolvidos.

O uso de um Perfil externo não elimina a responsabilidade local pelo risco.

Capítulo 30 — Tiers de Implementação e integração corporativa

Use os Tiers do CSF para caracterizar práticas de governança e gestão de risco cibernético no contexto. As discussões devem apoiar decisões sobre características desejadas e investimento sem tratar um Tier como nível de certificação ou meta automática.

Integre risco cibernético com gestão de riscos corporativos e planejamento da força de trabalho quando útil, preservando responsabilidade e evidência de decisão.

Capítulo 31 — Referências informativas, crosswalks e asseguuração

Use referências informativas para conectar resultados do CSF com outros padrões, controles, práticas ou requisitos. Mantenha identidade e versão da fonte, justificativa do mapeamento, direção, limitações, procedência e validação.

Mapeamentos legíveis por máquina ou assistidos por IA exigem avaliação contínua e revisão humana. Um mapeamento não prova equivalência entre requisitos nem que um resultado foi alcançado.

A asseguuração deve distinguir desenho, implementação, operação e qualidade da evidência. Opiniões formais exigem julgamento independente competente e evidência suficiente e apropriada.

Capítulo 32 — Liberação, manutenção e melhoria contínua

O Manual 09 só é encerrado quando verificação de fontes, mestre controlado, revisão técnica/editorial/de segurança, localização e revisão semântica humana, acessibilidade, QA de publicação, revisão de segurança do repositório/workflows, procedência, reconciliação de mudanças e Aprovação Humana Final de Liberação estiverem completas para o mesmo candidato exato.

Mudanças materiais posteriores devem acionar análise de impacto e, quando apropriado, novo ciclo controlado de revisão.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.